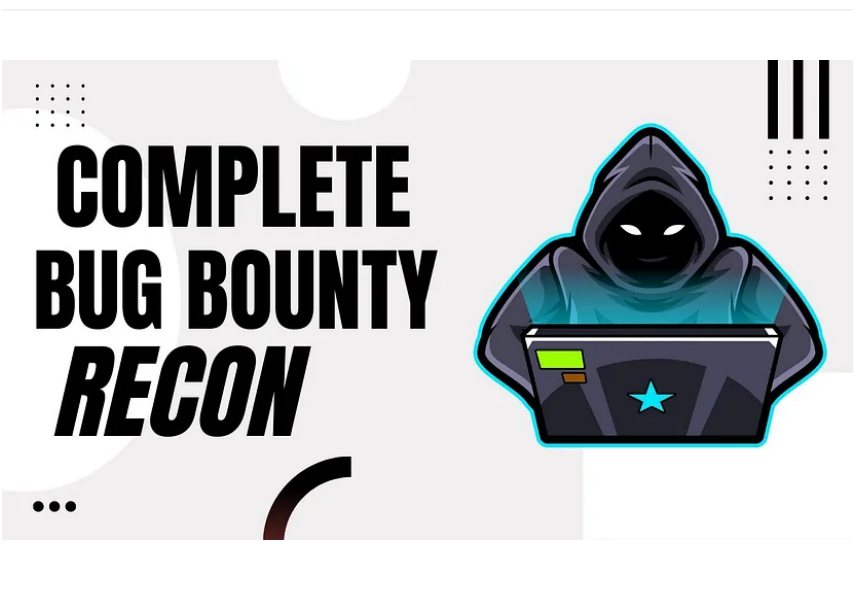
Get unlimited access to the best of Medium for less than $1/week. Become a member

Complete Bug Bounty Recon Fundamentals.

Sagar Shewale · Follow
11 min read · Apr 26, 2023

481 11



Hello dear hackers, welcome back to my new blog, I hope so you all are good !!
So today, in this blog, we are going to discuss about complete bug bounty recon fundamentals, tips, tricks and all types of techniques.
Recon is the first and most important part of hacking, either it could be pentesting or bug bounty.
If you are perfect in recon process, then you are vulnerability analysis process and exploitation process will be lot more easy.

Before start writing the blog, I have such a small request to all of you, I always right articles on cyber security, ethical hacking, penetration testing. So if you didn't follow, then follow me first and clap on this article, because that's give me a motivation to write something new !!

If you didn't follow me on my social, here is my twitter & linkedin.

☛ My-Twitter
☛ My-Linkedin

Thank you !!!
Let's Start !!!

. . .

1) Google Dorks :
Google dorks it's nothing but, it's google search filters, where you can search particular link, keyword, title or file types of exact particular website.

¶ Let's check some Google dorks as follows ¶

✦ **site:google.com** (It will gives you, only "example.com" site result)
✦ **intext:"hello man"** (It will only showing you TEXT that, you put into intext)
✦ **inurl:"admin"** (It will only showing you keyword that is inside the URL)
✦ **intitle:"password"** (It will show you at the title as a main header)
✦ **filetype:pdf** (It will show you only, particular file type result of particular site)
✦ **link:www.google.com** (When you use the link keyword followed by the URL, it will show you all the site that link back to the URL specified.)
✦ **allintext:"Hello Man"** (If you use the allintext keyword, Google will restrict your search to those pages that have ALL of the search terms you specify in the text of the page.)
✦ **allinurl:"admin"** (If you use the allinurl keyword, Google will restrict your search to those pages that have ALL of the search terms you specify in the URL of the page.)
✦ **allintitle:"password"** (If you use the allintitle keyword, Google will restrict your search to those pages that have ALL of the search terms you specify in the title of the page.)
✦ **info:www.google.com** (It will gives you information of given web page)
✦ **related:www.google.com** (It will gives list web pages that are "similar" to a specified web)
✦ **cache:www.google.com** (If you include other words in the query, Google will highlight those words within the cached document.)
✦ **define:"Hacker"** (The query will provide a definition of the words you enter after it, gathered from various online sources.)
✦ **before: 2010** (It will show you result of site before 2010)
✦ **after: 2010** (It will show you result of site after 2010)
✦ **ext:php** (Used to find out particular extention of given site)
Here is some google dorks which helps you in bug bounty recon

¶ I'm going to gives you, some additional dorks which will help you for OSINT. ¶

✦ **phonebook: "India"** (Search phonebook releted query)
✦ **maps: "America"** (Search particular location)
✦ **book: "bug bounty bootcamp"** (Search particular books)
✦ **movie:Avengers** (Search particular movies)
✦ **weather:London** (Search weather of any particular city)

¶ Some operator to use in google dorks.¶

→ * (Means wildcard character, that means DISPLAY EVERYTHING)

→ " " (Means quotation mark, that means DISPLAY EXACT KEYWORD, it only use for intext, inurl, intitle,defile dorks OR use for search any strings type of keyword)

→ | (Means PIPE Symbol, which is use for "either this or that" type of statement, let me explain with following dork example)
inurl: "admin" | inurl: "login" (you can also write, **inurl: "admin" OR inurl: "login"**)
As you can see above 2 inurl dorks, in this case, google will try to find out 1st keyword of left side of PIPE, if it got admin keyword the OK!! OTHERWISE it will try 2nd dork, means right side of PIPE and try to find login keyword

→ AND (It return result with all given keywords.)
"USA" AND "China" (It will gives result of both keywords.)

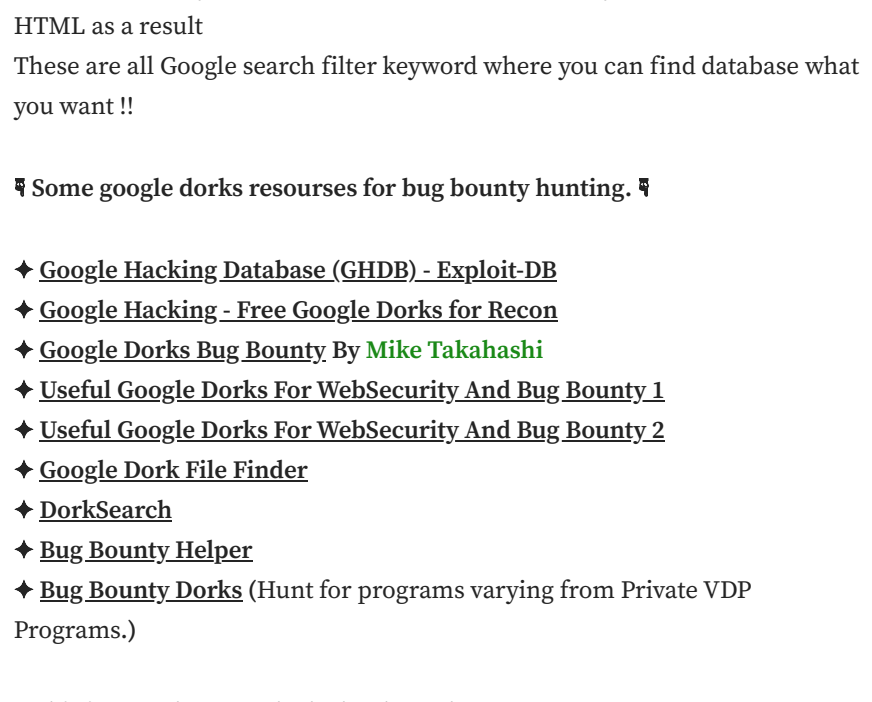
→ intex/inurl/intitle (It searches for term designated area.)

You can also use " — "symbol to **exclude** any result in google dorks, you can say this minus sign OR dash OR hyphen
For Exmaple, **site:google.com intext: "programming" -inurl:HTML**
In this example, you can see intext programming but you can't see inurl HTML as a result
These are all Google search filter keyword where you can find database what you want !!

¶ Some google dorks resourses for bug bounty hunting. ¶

✦ Google Hacking Database (GHDB) - Exploit-DB
✦ Google Hacking - Free Google Dorks for Recon
✦ Google Dorks Bug Bounty By Mike Takahashi
✦ Useful Google Dorks For WebSecurity And Bug Bounty 1
✦ Useful Google Dorks For WebSecurity And Bug Bounty 2
✦ Google Dork File Finder
✦ DorkSearch
✦ Bug Bounty Helper
✦ Bug Bounty Dorks (Hunt for programs varying from Private VDP Programs.)

¶ This is complete google dorks cheat sheet. ¶



❋ All types of google search operators ❋

◆ ◆ ◆

2) SSL Enumeration :
SSL enumeration, is the enumeration where you are gatharing the information about SSL certificate of that particular web application.
There are lots of tricks and technique to gather information about it.

Let's check one by one as follow !!

★ SSL Enumeration Using Nmap ★
☛ Script `ssl-cert`
☛ Script `ssl-cert-intaddr`
☛ Script `ssl-date`
☛ Script `ssl-dh-params`
☛ Script `ssl-enum-ciphers`
☛ Script `ssl-heartbleed`
☛ Script `ssl-known-key`
☛ Script `ssl-poodle`

★ SSL Scanning Tools ★
☛ Sslscan
☛ S3scanner
☛ Sslyze
☛ TLSSLed
☛ Sslh

★ Online SSl Scanner ★
☛ ssllabs
☛ SSL Tools
☛ SSL/TLS Scanner

◆ ◆ ◆

3) CMS Enumeration :
A Content Management System (CMS) is an application that is used to manage content, allowing multiple contributors to create, edit and publish.
Using following tools you can gather information about CMS
☛ cmseek
☛ joomscan
☛ wpscan

★ Online CMS Scanning Tools ★
☛ What CMS
☛ CMS Detector

◆ ◆ ◆

4) DNS Enumeration :
DNS enumeration is the process of locating all the DNS servers and their corresponding records for an organization. A company may have both internal and external DNS servers that can yield information such as usernames, computer names, and IP addresses of potential target systems

★ DNS Enumeration Using Nmap ★
☛ Script `dns-blacklist`
☛ Script `dns-brute`
☛ Script `dns-nsec-enum`
☛ Script `dns-srv-enum`
☛ Script `dns-zone-transfer`
☛ Script `dns-nsid`
☛ Script `dns-fuzz`
☛ Script `dns-check-zone`

★ DNS Scanning Tools ★
☛ dig
☛ Nslookup
☛ BIND9
☛ Dnsrecon
☛ Dnsenum
☛ Dnstwist
☛ Dnsx
☛ GoogleDNS
☛ msdnsscan
☛ host
☛ whois

★ Online DNS Scanner ★
☛ dnsdumpster
☛ Netcraft
☛ ICANN Lookup
☛ Domain Tools
☛ Robtex
☛ DNSlytics
☛ CentralOps
☛ DNSLytics
☛ Dmitry (Multipurpose tool used to DNS Lookup, IP Lookup,gather Netcraft info, port scanning and many more)

◆ ◆ ◆

5) Technology Enumeration :
Technology enumeration is the process where you can find about technology, webserver, operating system, web hosting, CMS, CDN, Programming language, behind the websites

★ There are some tools to find out the web technology enumeration ★
☛ Wappalyzer
☛ BuiltWith
☛ WhatWeb
☛ Netcraft
☛ Retire.js
☛ httpx-toolkit
☛ Nuclei (One of the most powerfull and ultimate tool for multipurpose web activity)

Wappalyzer, BuiltWith are the useful extention for hackers.
I already written the blog on hackers extention, if you don't read that blog then this is the link. ¶

⇨ ***Top 15 Browser Extensions For Hackers, Which Every Pentester Should Know !!***

◆ ◆ ◆

6) WAF Enumeration :
WAF stands for Web Application Firewall
I'ts the process of enumeration, where you can detect the firewall which is running behind the website.

★ There are some tools and some nmap scripts to enumerate web application firewall. ★
☛ Wafw00f
☛ Script `http-waf-detect`
☛ Script `http-waf-fingerprint`
☛ Script `firewall-bypass`

◆ ◆ ◆

7) Port Discovery :
A port discovery or port scanning is a common technique, where hackers use to discover open doors or weak points in a network. A port scan attack helps cyber criminals find open ports and figure out whether they are receiving or sending data. It can also reveal whether active security devices like firewalls are being used by an organization.

When hackers send a message to a port, the response they receive determines whether the port is being used and if there are any potential weaknesses that could be exploited.

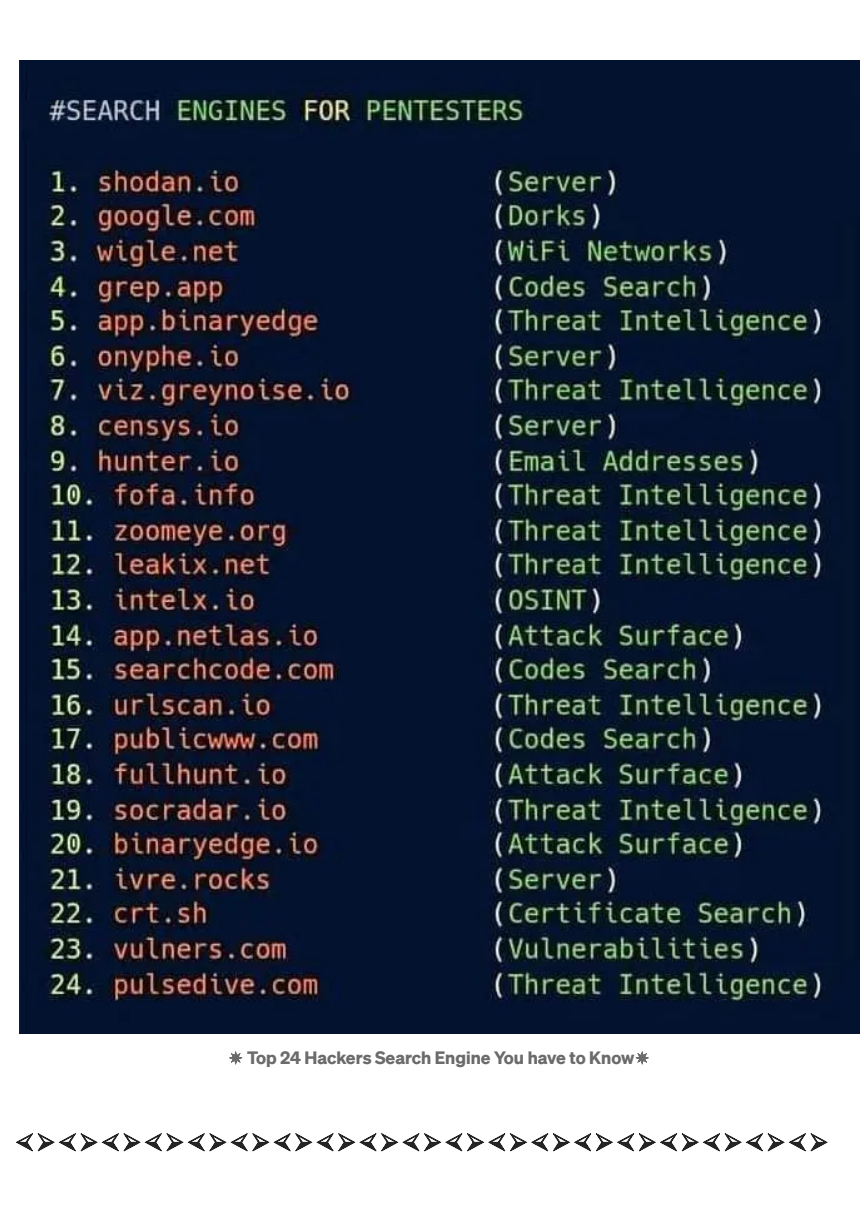
★ There are some tools to use for port discovery. ★
☛ Nmap
☛ Masscan
☛ RustScan

◆ ◆ ◆

8) Online Hacker Search Engine :
Online hacker search engine is a platform, where you can search all various types of servers connected to the internet using a variety of filters. Some have also described it as a search engine of service banners, which are metadata that the server sends back to the client.

★ There are some search engines, to get information passively for bug bounty ★
☛ Shodan (Python library for terminal)
☛ Censys (Python library for terminal)
☛ Hunter
☛ Zoomeye
☛ GrayNoice

¶ Category wise hacker search engine list ¶



```
#SEARCH ENGINES FOR PENTESTERS

1. shodan.io                (Server)
2. google.com               (Dorks)
3. wigle.net                (WiFi Networks)
4. grep.app                 (Codes Search)
5. app.binaryedge           (Threat Intelligence)
6. onyphe.io                (Server)
7. viz.greynoise.io         (Threat Intelligence)
8. censys.io                (Server)
9. hunter.io                (Email Addresses)
10. fofa.info               (Threat Intelligence)
11. zoomeye.org             (Threat Intelligence)
12. leakix.net              (Threat Intelligence)
13. intelx.io               (OSINT)
14. app.netlas.io           (Attack Surface)
15. searchcode.com          (Codes Search)
16. urlscan.io              (Threat Intelligence)
17. publicwww.com           (Codes Search)
18. fullhunt.io             (Attack Surface)
19. socradar.io             (Threat Intelligence)
20. binaryedge.io           (Attack Surface)
21. ivre.rocks              (Server)
22. crt.sh                  (Certificate Search)
23. vulners.com             (Vulnerabilities)
24. pulsedive.com           (Threat Intelligence)
```

❋ Top 24 Hackers Search Engine You have to Know❋

◆ ◆ ◆

9) Web Crawling :
What is web crawling? Web crawling is the process of indexing data on web pages by using a program or automated script.
These automated scripts or programs are known by multiple names, including web crawler, spider, spider bot, and often shortened to crawler.
Basically web crawler find out the hidden endpoints of website.

★ There are some tools for web crawling and parameter endpoint searching ★
☛ Arjun
☛ LinkFinder
☛ SecretFinder
☛ Gospider
☛ Paramspider
☛ Hakrawler
☛ Meg
☛ Crawley
☛ X8
☛ Getallurls
☛ SpiderSuite

★Here are some tools to crawl and take the screenshot of website★
☛ Eyewitness
☛ Gowitness
☛ Aquatone
☛ Httrack
☛ Pikwy

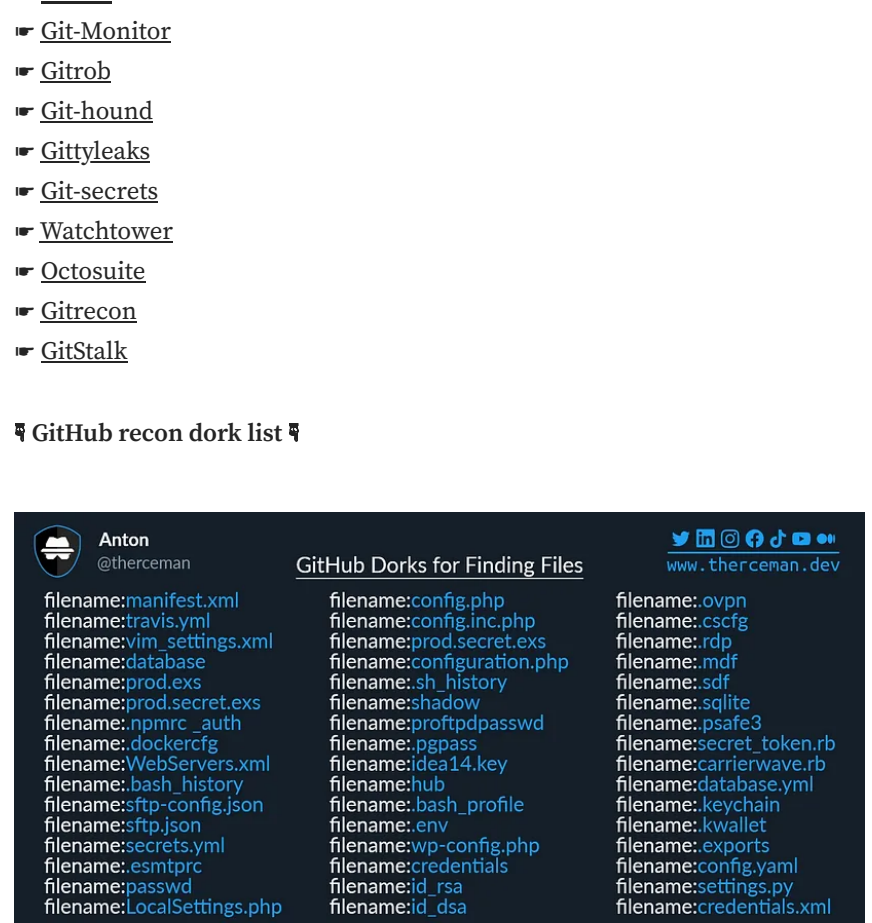
◆ ◆ ◆

10) GitHub Reconnaissance :
Github recon is the process, where you can gather the information from github which is intentionally or unintentionally exposed by web developer.

In github recon, you can find sensetive data such as API key, private PGP key, usernames, passwords, email address, logs etc.

★ There are some following tools useful for git recon ★
☛ Trufflehog
☛ GitHub-Dorks
☛ GitGot
☛ Git-Monitor
☛ Gitrob
☛ Git-hound
☛ Gittyleaks
☛ Git-secrets
☛ Watchtower
☛ Octosuite
☛ Gitrecon
☛ GitStalk

¶ GitHub recon dork list ¶



Anton
@therceman
www.therceman.dev

GitHub Dorks for Finding Files

filename:manifest.xml
filename:travis.yml
filename:vim_settings.xml
filename:database
filename:prod.exs
filename:prod.secret.exs
filename:.npmrc _auth
filename:.dockercfg
filename:WebServers.xml
filename:.bash_history
filename:sftp-config.json
filename:sftp.json
filename:secrets.yml
filename:.esmtprc
filename:passwd
filename:LocalSettings.php

filename:config.php
filename:config.inc.php
filename:prod.secret.exs
filename:configuration.php
filename:.sh_history
filename:shadow
filename:proftpdpasswd
filename:.pgpass
filename:idea14.key
filename:hub
filename:.bash_profile
filename:.env
filename:wp-config.php
filename:credentials
filename:id_rsa
filename:id_dsa

filename:.ovpn
filename:.cscfg
filename:.rdp
filename:.mdf
filename:.sdf
filename:.sqlite
filename:.psafe3
filename:secret_token.rb
filename:carrierwave.rb
filename:database.yml
filename:.keychain
filename:.kwallet
filename:.exports
filename:config.yaml
filename:settings.py
filename:credentials.xml

GiHub Dorks for Finding API Keys, Tokens and Passwords

api_key
authorization_bearer:
oauth
auth
authentication
client_secret
api_token:
client_id

OTP
HOMEBREW_GITHUB_API_TOKEN
SF_USERNAME
HEROKU_API_KEY
JEKYLL_GITHUB_TOKEN
shodan_api_key
api.forecast.io

password
user_password
user_pass
passcode
client_secret
secret
password hash
user auth

GiHub Dorks Automation Tools

```
TruggleHog   - https://github.com/dxa4481/truffleHog
Github-Dorks - https://github.com/techgaun/github-dorks
GitGot       - https://github.com/BishopFox/GitGot
GitMonitor   - https://github.com/Talkaboutcybersecurity/GitMonitor
GitRob       - https://github.com/michenriksen/gitrob
GitHound     - https://github.com/tillson/git-hound
GittyLeaks   - https://github.com/kootenpv/gittyleaks
GitSecrets   - https://github.com/awslabs/git-secrets
Watchtower   - https://radar.nightfall.ai
```

❋ Cradit- Anton (therceman) ❋

◆ ◆ ◆

11) Fuzzing & Content Discovery :
According to OWASP definition, **Fuzzing** is the art of automatic bug finding, and it's role is to find software implementation faults, and identify them if possible.

In content discovery, content can be different types such as images, files, videos, and so on. There are 3 main ways to discover content on web pages which are: Manually, Automated, OSINT (Open-Source Intelligence) methods.

★ There are following tools useful for fuzzing and content discovery ★
☛ Dirb
☛ Dirbuster
☛ Gobuster
☛ Dirsearch
☛ Wfuzz
☛ FFUF
☛ Feroxbuster
☛ Kiterunner

★ Some payload resourses ★
☛ SecLists
☛ Wordlists
☛ PayloadsAllTheThings
☛ Fuzzdb
☛ PayloadBox

◆ ◆ ◆

12) Subdomain Enumeration :
Subdomain enumeration is the process of finding sub-domains for one or more domains. It helps to broader the attack surface, find hidden applications, and forgotten subdomains.

★ There are two types of subdomain enumeration techniques ★
✪ Active subdomain enumeration
✪ Passive subdomain enumeration

Let's check one by one

✪ Active subdomain enumeration :
There are some types of active subdomain enumeration as follows
➾ Brute Force Enumeration (ffuf, wfuzz, dirbuster)
➾ Zone Transfer (nslookup, dig, dnsrecon tool)
➾ DNS Records (A, AAAA, MX, TXT, CNAME, NS Records using dnsrecon tool)

✪ Passive subdomain enumeration :
There are some types of passive subdomain enumeration as follows
➾ Tools
➾ Certificate Transparency [crt.sh] **OR** [Github-Repo] **OR** [NSE Script]
➾ Google Dorking (we discussed about it !!)

★ There are some tools to get subdomain passively ★
☛ Knockpy
☛ Sublist3r
☛ Turbolist3r
☛ Subfinder
☛ Assetfinder
☛ Amass
☛ Findomain
☛ Subbrute
☛ Chaos

These are some tools to get sobdomain

Here we are finishing the **Bug Bounty Recon Fundamentals !!**
Let's Discuss About Some Bonus Tips

◆ ◆ ◆

★ BONUS TIPS ★
☛ Bug hunting getting lot more easy, it depends upon your recon, if you do deep recon, then there are lots of chances increases to got bug.

☛ Most of the times we need, a tools with multiple functionality such as Checker tools, Text tools, Converter tools, Generator tools, Developer tools and so many things but don't worry, I got solution ***ViewDNS*** is online web site including over 350+ quick & easy to use web tools.
You must check it out, I promise you will never disappoint.

☛ Store every historical data, that you find from different sources including your recon data, all subdomains, your exploits, payloads and everything that you gather.

☛ Keep updated the given hacking tools regularly on your attacker machine.

☛ Keep learning new things and don't forget to update and grow your knowledge.

☛ Make cheat sheet of payload OR make it always ready to your PC
above I just give payload resources. Check it out !!

☛ Learn from your mistakes, it will make you perfet !!

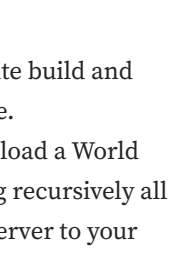
☛ Read articles, blogs, published reports on cyber security and bug bounty daily.

https://md5decrypt.net/en/Conversion-tools/

☛ Make checklist of url and vulnerabilities. If you want to perform it better then use note keeping sofware as follows
➾ Evernote
➾ Notion
➾ Cherrytree
➾ **This** checklist you should never miss !!!
➾ **This** is most useful source for you !!!

☛ Write a proper bug bounty report after found a bug.
If you don't know, how to write a bug bounty report, then this is the link go and check it out ¶

How To Write Bug Bounty Report.
Hello beautiful hackers, how are you, hope you are good. So today, in this blog, I am going to teach you how to write a...
medium.com



☛ The "Chaos" is most beautiful project discovery platform.
If you boared with hackerone and bugcrowd then try it.
GitHub-Repo-Of-Chaos (as I already mention above this tool is also useful for finding subdomain.)

☛ Use all "tomnomnom-github-tools" for bug bounty, i'ts such a useful tools

☛ "reNgine" is an automated reconnaissance framework for web applications with a focus on highly configurable streamlined recon process via engines.
Use reNgine tool, if you are master in manual recon

☛ RreconFTW is a tool designed to perform automated recon on a target domain by running the best set of tools to perform scanning and finding out vulnerabilities

☛ "Nuclei" is a most populer YAML templete based, web vulnerability scanner which you must use, while recon or exploiting.
This is the guide to use nuclei tool

➾ ***The Ultimate Guide to Finding Bugs With Nuclei***

☛ "Ciphey" tool, which is fully automated decryption/decoding/cracking tool using natural language processing & artificial intelligence, along with some common sense.

☛ You should understand website structure that, how website build and other. So you have to copy the website in your local machine.
"Httrack" is an offline browser utility, allowing you to download a World Wide website from the Internet to a local directory, building recursively all directories, getting html, images, and other files from the server to your computer.

☛ "CyberChef" the cyber swiss army knife — a web app for encryption, encoding, compression and data analysis.

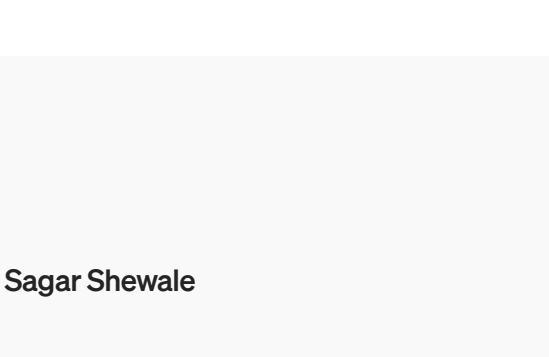
☛ Conversion-tools is the good tool for you to detect automatic hashes and decode them !!!

☛ "Nmmapper" offloading cybersecurity defense tools from nmap to subdomain finder, theHarvester

☛ "Waybackurl" is most popular and powerfull tool ever, and your best friend as well which you can get multiple vulnerable endpoint parameter and vulnerable URLs.
Don't forget to check it out

◆ ◆ ◆

I hope you guys enjoy the blog.
If you like it, then don't forget to follow, subscribe and claps.
I'll see you with next article.

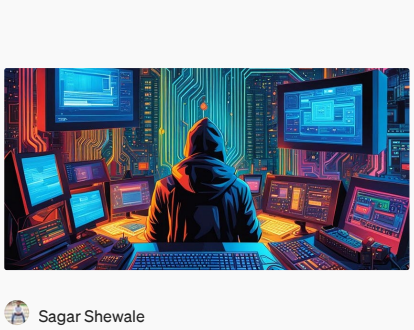


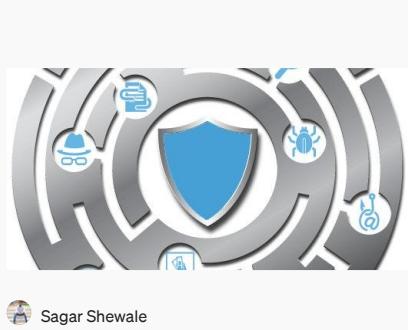
Hacking · Hacker · Medium · Tips · Bug Bounty

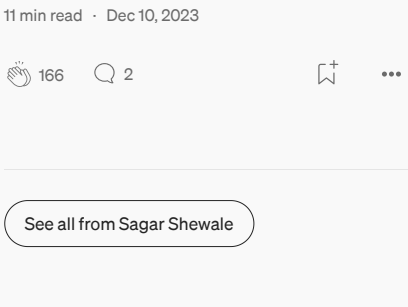
481 11

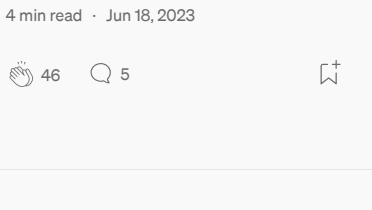
Written by Sagar Shewale
3K Followers
Penetration Testing | Linux | CTF | Hacking | OSINT | Bug Bounty Hunting |
https://twitter.com/imshewale
Follow

More from Sagar Shewale


Sagar Shewale
Complete WiFi Hacking Methodology.
Hello dear hackers, welcome back to my new article. Hope you all are good happy and...
7 min read · Aug 26, 2023
459 9

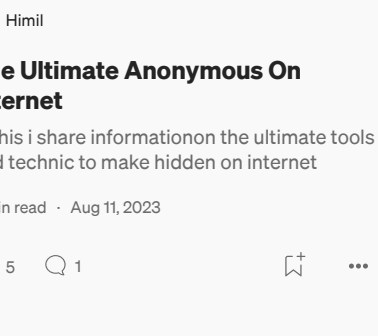

Sagar Shewale
Top 15 Best Port Forwarding Services.
Hello hackers, welcome back to my new blog, hope you all are good. Today in this blog we...
7 min read · Jun 11, 2023
22

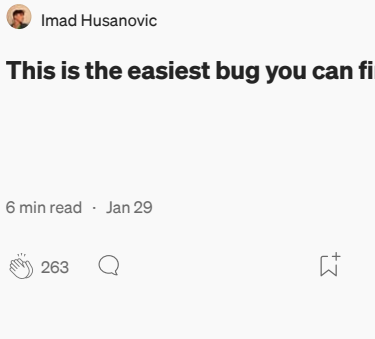

Sagar Shewale
Complete Red Team Recon Fundamentals.
Hello my dear friends, welcome back to my new article. This is your friend Sagar. I hope...
11 min read · Dec 10, 2023
166 2


Sagar Shewale
Top 15 Best CTF For OSINT Practice.
Hello hackers, welcome back to my new blog, hope you all are good. Today in this blog, I'm...
4 min read · Jun 18, 2023
46 5

See all from Sagar Shewale

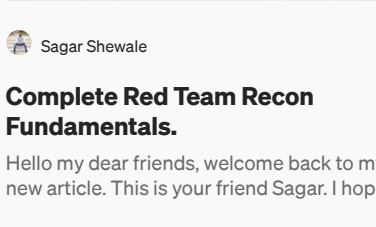
Recommended from Medium

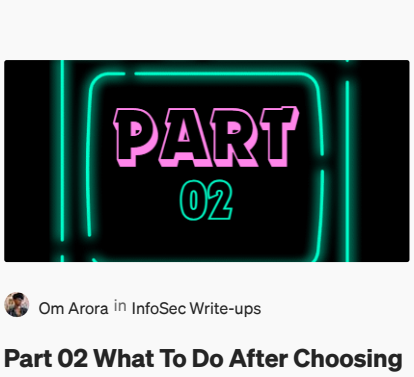

Himil
The Ultimate Anonymous On Internet
in this i share informationon the ultimate tools and technic to make hidden on internet
5 min read · Aug 11, 2023
5 1

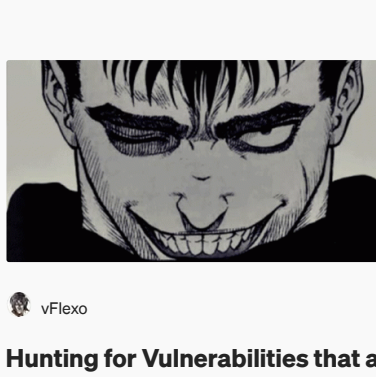

Imad Husanovic
This is the easiest bug you can find.
6 min read · Jan 29
263

Lists
How to Boost Employee Experience With Career...
7 stories · 115 saves
Stories to Help You Grow as a Designer
11 stories · 537 saves
Medium's Huge List of Publications Accepting...
262 stories · 1813 saves
Productivity 101
20 stories · 1205 saves

Batuhan Aydın
Bug Bounty Hunter — Recon is everything / Part 1
Hello folks, I'm thrilled to be back after a long hiatus. I'm back, and today I'll be sharing...
7 min read · Sep 2, 2023
446 2


Sagar Shewale
Complete Red Team Recon Fundamentals.
Hello my dear friends, welcome back to my new article. This is your friend Sagar. I hope...
11 min read · Dec 10, 2023
166 2


Om Arora in InfoSec Write-ups
Part 02 What To Do After Choosing a Target? | Bug Bounty
Hello Everyone,
6 min read · Nov 10, 2023
375 6


vFlexo
Hunting for Vulnerabilities that are ignored by most of the Bug Bount...
Hey Guys! Hope y'all doing well.
8 min read · Jan 28
503 6

See more recommendations